

RESPOND AND RECOVER FROM A DATA BREACH

PROJECT DESCRIPTION

This is a capstone project. In this lab activity, I'll apply knowledge of cloud cybersecurity to identify and remediate vulnerabilities. The tasks in the scenario require me to use skills to work, analyze and remediate active vulnerabilities relating to a security incident in the Google Cloud Security Command Center.

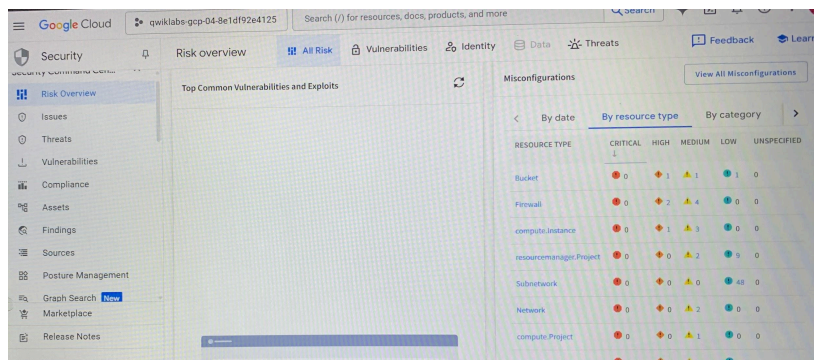
SCENARIO

Recently, my company has experienced a massive data breach. As a junior member of the security team. I'll help support the security team through the lifecycle of this security incident. I began by identifying the vulnerabilities related to the breach, isolating and containing the breach to prevent further unauthorized access, recover the compromised systems, remediate any outstanding compliance related issues and verify compliance with frameworks.

FIRST STEP: ANALYZE THE DATA BREACH AND GATHER INFORMATION

The first step towards understanding the scope and impact of this breach is to gather information and analyze the available data.

In this step, I examined the vulnerabilities and findings in Google Cloud Security Command Center to determine how the attackers gained access to the data, and which remediation steps to be taken.



RESOURCE TYPE	CRITICAL	HIGH	MEDIUM	LOW	UNSPECIFIED
Bucket	0	1	1	1	0
Firewall	0	2	4	0	0
compute instance	0	1	3	0	0
resourceManager Project	0	0	2	0	0
Subnetwork	0	0	0	0	0
Network	0	0	2	0	0
compute Project	0	0	1	0	0
ServiceAccountKey	0	0	1	0	0

After navigating the SCC, I observed an overview of the active vulnerabilities. I noted that there are both high and medium severity findings relating to the **cloud storage bucket, compute instance virtual machine** and **firewall**.

I examined the PCI DSS 3.2.1 report. Here, I noticed a list of rules that are non-compliant, which relate to the data breach;

- 1. Firewall rule logging should be enabled so you can audit network access:** This medium severity indicates that firewall rule logging is disabled, meaning that there is no record of which firewall rules are being applied and what traffic is being allowed or denied.
- 2. Firewall rules should not allow connections from all IP addresses on TCP or UDP port 3389:** This high severity indicates that the firewall is configured to allow Remote Desktop Protocol traffic for all instances in the network from the whole internet.

3. **Firewall rules should not allow connections from all IP addresses on TCP or SCTP port 22:** This high severity indicates that the firewall is configured to allow Secure Shell(SSH) traffic to all instances in the network from the whole internet.
4. **VMs should not be assigned public IP addresses:** This high severity indicates that a particular IP address is actively exposed to the public internet and is potentially accessible to unauthorized individuals.
5. **Cloud storage buckets should not be anonymously or publicly accessible:** This high severity indicates that there is an ACL entry for the storage bucket that is publicly accessible.
6. **Instances should not be configured to use the default service account with full access to all Cloud APIs:** This medium severity indicates that a particular identity or service account has been granted full access to all Google Cloud APIs.

I filtered the findings for further examination and analysis of the vulnerabilities in the Google environment.

The following active findings pertain to the storage bucket;

1. **Public bucket ACL**
2. **Bucket policy only disabled**
3. **Bucket logging disabled**

These findings indicate that the bucket is configured with a combination of security settings that could expose the data to unauthorized access. I remediated these findings by removing the public access control list, disabling public bucket access.

The following active findings pertain to the virtual machine named **cc-app-01**;

1. **Malware bad domain**
2. **Compute secure boot disabled**
3. **Default service account used**
4. **Public IP address**
5. **Full API access**

These findings indicate the virtual machine was configured in a way that left it very vulnerable to the attack. I remediated these findings by shutting the original VM (cc-app-01) down and creating a VM (cc-app-02) using a clean snapshot of the disk. The new VM will have the following settings in place:

- a. **No compute service account**
- b. **Firewall rule tag for a new rule for controlled SSH access**
- c. **Secure boot enabled**
- d. **Public IP address set to none.**

The following active findings pertain to the firewall;

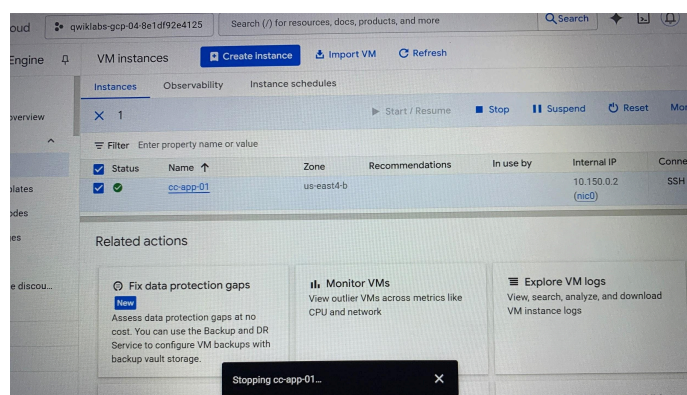
1. **Open SSH port**
2. **Open RDP port**
3. **Firewall rule logging disabled**

These findings are listed in the PCI DSS report and highlight a significant security gap in the network configuration. The lack of restricted access to RDP and SSH ports, coupled with

disabled firewall rule logging, makes the network highly vulnerable to unauthorized access attempts and potential data breaches. I remediated these by removing existing firewall overly broad rules and replacing them with a firewall rule that allows SSH access only from the addresses that are used by Google Cloud's IAP SSH service.

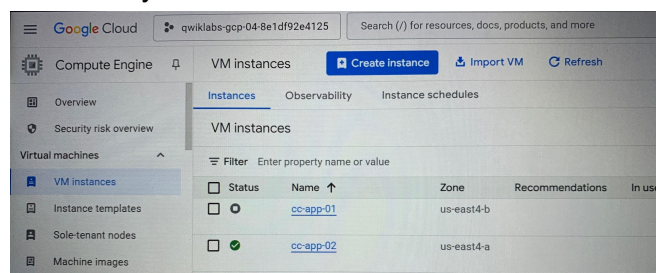
SECOND STEP: FIX THE COMPUTE ENGINE VULNERABILITIES

Here, I shut down the vulnerable VM **cc-app-01** and created a new VM from a snapshot taken before the malware infection.



The **cc-app-02** VM instance will restart and the **Secure Boot disabled** finding will be remediated.

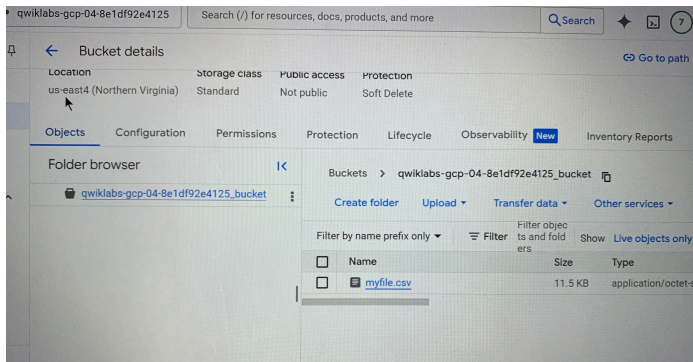
After this step, I have effectively created a new VM from the snapshot, ensuring it is free from malware and misconfigurations. I also deleted the compromised VM, eliminating the source of the security breach.



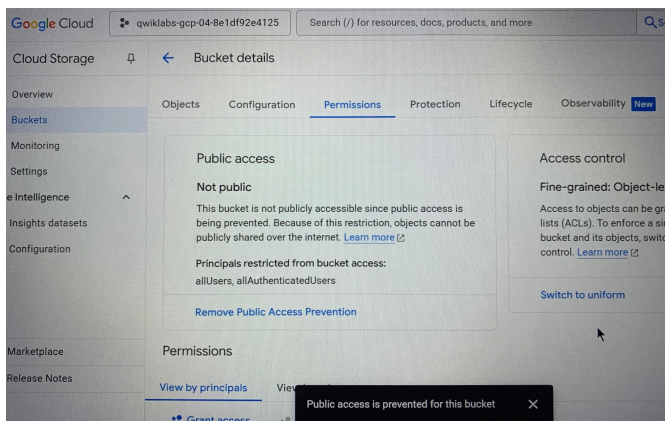
THIRD STEP: FIX CLOUD STORAGE BUCKET PERMISSIONS

Here, I revoked public access to the storage bucket and switched to uniform bucket-level access control, significantly reducing the risk of data breaches. By removing all user permissions from the storage bucket, I can prevent unauthorized access to the data stored within.

I noted that there is a **myfile.csv** file in the publicly accessible bucket. This is the file that contains the sensitive information that was dumped by the malicious actor.

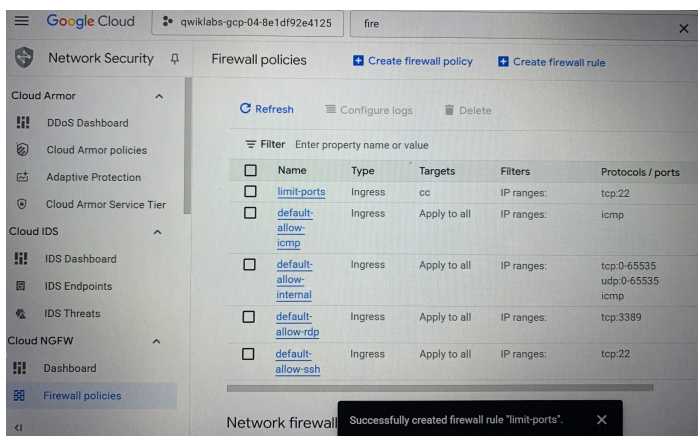


After this step, I have effectively prevented public access to the bucket, switched to uniform bucket-level access control and removed all users permissions addressing the **Public bucket ACL**, **Bucket policy only disabled** and **Bucket logging disabled** findings.



FOURTH STEP: LIMIT FIREWALL PORTS ACCESS

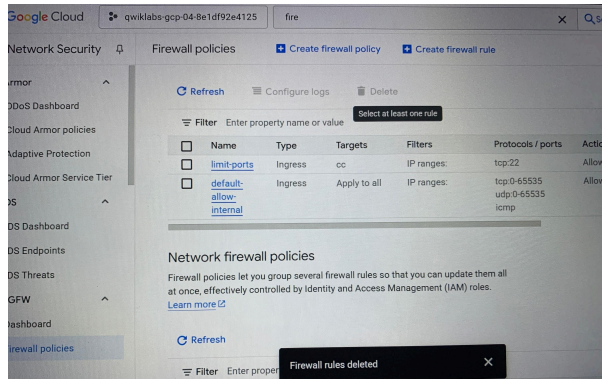
Here, I restricted access to RDP and SSH ports to only authorized source networks to minimize the attack surface and reduce the risk of unauthorized remote access.



FIFTH STEP: FIX THE FIREWALL CONFIGURATION

Here, I deleted three specific VPC firewall rules that are responsible for allowing unrestricted access to certain network protocols, namely; ICMP, RDP, SSH from any source within the VPC network. Then, I enabled logging on the remaining firewall rules.

The new firewall rule better protects the network and improves network visibility.



FINAL STEP: VERIFY COMPLIANCE

After diligently addressing the vulnerabilities identified in the PCI DSS 3.2.1 report, it's crucial to verify the effectiveness of my remediation efforts. In this task, I ran the report again to ensure that the previously identified vulnerabilities have been successfully mitigated and no longer pose a security risk to the environment.

CONCLUSION

With this lab experience, I can confidently assist to mitigate the impact of a data breach, address the vulnerabilities and significantly enhance security posture.